

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies — “No, since Employee password requirements are minimal, which could allow a threat actor to more easily access secure data/other assets via employee work equipment/the internal network.”
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system

- | | | |
|-------------------------------------|--------------------------|--|
| ☒ | ☐ | Locks (offices, storefront, warehouse) |
| ☒ | ☐ | Closed-circuit television (CCTV) surveillance |
| ☒ | ☐ | Fire detection/prevention (fire alarm, sprinkler system, etc.) |

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.

- | | | |
|-------------------------------------|--------------------------|--|
| ☒ | ☐ | There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. |
| ☒ | ☐ | Ensure data is properly classified and inventoried. - “No. Since current assets have been inventoried/listed, but not classified.” |
| ☒ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |

System and Organizations Controls (SOC type 1, SOC type 2)

- | Yes | No | Best practice |
|-------------------------------------|-------------------------------------|---|
| ☒ | ☐ | User access policies are established. - “No, since Controls of Least Privilege and separation of duties are not currently in place; all employees have access to internally stored data.” |
| ☐ | ☒ | Sensitive data (PII/SPII) is confidential/private. |
| ☒ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☒ | ☐ | Data is available to individuals authorized to access it. - “No, since while data is available to all employees, authorization needs to be limited to only the individuals who need access to it to do their jobs.” |

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys’ security posture.

- It is recommended to implement the principle of least privilege and the separation of duties; this involves controlling the number of individuals with access to sensitive data, restricting internal employee access to stored data, and reducing the attack surface, thereby further safeguarding user data security.
- Data should be encrypted during receipt, processing, transmission, and local database storage to prevent unauthorized parties from directly utilizing the data if accessed.
- Installing an intrusion detection system is recommended to ensure timely alerts and proactive responses in the event of an intrusion.
- A disaster recovery plan should be actively developed, and critical company data backed up, to ensure data integrity and availability in the event of an unexpected incident.
- Company password policies should be upgraded; passwords failing to meet current minimum complexity standards must be rejected and mandatory changes enforced. Additionally, a centralized password management system that enforces minimum policy requirements should be implemented to further ensure password security and effectiveness.
- Legacy systems require monitoring and maintenance, including regular upkeep and appropriate intervention measures.

Multiple controls need to be implemented to improve Botium Toys' security posture and better ensure the confidentiality of sensitive information, including: Least Privilege, disaster recovery plans, password policies, separation of duties, an IDS, ongoing legacy system management, encryption, and a password management system.

To address gaps in compliance, Botium Toys needs to implement controls such as Least Privilege, separation of duties, and encryption. The company also needs to properly classify assets, to identify additional controls that may need to be implemented to improve their security posture and better protect sensitive information.